Operationalizing Enterprise AI Security

An Open-Source Framework for AI Cyber Risk Management

Josh Harguess · **Chris M. Ward** · Eric Cardinal

Harguess, Ward: Fire Mountain Labs, San Diego, CA, USA

Cardinal: Delta Dental of California, San Francisco, CA, USA

harguess@firemountainlabs.com · chris@firemountainlabs.com

1 Motivation

TRADITIONAL CYBERSECURITY

- Deterministic: same input, same output
- Attacks exploit code, configuration, access
- Perimeter defense and patch management

AI SYSTEMS

- Non-deterministic: same prompt, different outputs
- Behavior steerable through inputs alone
- Attack surface: training data, weights, inference API

AI-specific risk classes

- **Prompt injection**
- **Data poisoning**
- **Model extraction**
- **AI output liability**
- **Agentic goal misalignment**

2 Framework Overview

PILLAR I 112 TERMS · 8 CATEGORIES
AI Definitions & Taxonomy

PILLAR II 171 RISKS · 14 CATEGORIES
AI Risk Taxonomy

PILLAR III 177 SUB-CONTROLS · 25 DOMAINS
AI Control Framework

- Bidirectional risk–control mapping
- Operationalizes NIST AI RMF MEASURE and MANAGE [4]

3 Pillar I: Definitions

- 112 terms; sources: ISO/IEC 22989, NIST AI 600-1, OWASP LLM Top 10
- Security implication stated in each definition
- e.g., *User Prompt*: primary attack vector for generative AI

4 Pillar II: Risk Taxonomy

171	108	63
TOTAL RISKS	AI-SPECIFIC	CYBER-TECHNICAL

AI RISK CATEGORY (14)	RISKS
AI System Security	23
Model Reliability & Drift	17
Model Training	16
Generative Output	9
Excessive Agency	9
Socio-economic & Environmental	8
Third-Party & Supply Chain	6
Bias & Discrimination	5
Accountability & Governance	4
Multi-Agent Systems	4
Over-Reliance	3
Explainability	2
Shadow AI	1
Competitive Lag	1

5 Risk Classification

RISK	CLASS	CONTROL PLACEMENT
Prompt injection AIR.029	Intentional, post-deployment	Runtime detection & response
Bias in training data AIR.015	Unintentional, pre-deployment	Data governance during curation

- Three axes, adapted from the MIT AI Risk Repository [3]: entity, intentionality, timing
- Adversarial entries cross-mapped to MITRE ATLAS tactics and techniques [5]

Shadow AI (AIR.083): no owner, review or telemetry; detection depends on network and API-gateway monitoring (AIMLT).

6 Pillar III: Controls

CODE	CORE AI/ML DOMAIN (15; 5 SHOWN)
AISDL	Secure data lifecycle
AIMDV	Model/agent validation & testing
AIMLT	Monitoring & telemetry
AIIR	Incident response & forensics
AIGPC	Governance, compliance & ethics
CODE	**AGENTIC DOMAIN (10; 5 SHOWN)**
AGAS	Goal alignment & safety
SI	Safe interruptibility
TIS	Tool instruction safety
HOD	Human oversight & decision
ARTS	Agentic red-team & simulation

7 AI Security Service Team

RISK	CAPABILITY AREA	CONTROL DOMAIN	CONTROL
R.AIR.058 Agent interaction & collusion	Detection & Response	AIMLT Monitoring & Telemetry	AIMLT.11 Behavioral drift & tool-usage monitoring
		AIIR Incident Response & Forensics	AIIR.1 AI & agent-aware IR playbook
	Adversarial Testing	ARTS Agentic Red-Team & Simulation	ARTS.2 Multi-agent simulation
	Infrastructure	AIIEH Infrastructure Hardening	AIIEH.11 Agent sandbox & egress control
	Agentic Safety	AII Agent Interaction & Isolation	AII.1 Agent trust boundary & segmentation

Source: AI Cyber Risk Framework, R.AIR.058

8 Release and Future Work

- CC BY 4.0 spreadsheets: github.com/FireMountainLabs/ai-cyber-risk-framework
- Controls specify requirements, not implementation
- Future: maturity indicators per domain; expanded agentic coverage

9 References

[1] J. Harguess and C. M. Ward. Is the next winter coming for AI? The elements of making secure and robust AI. In *Trustworthy and Socially Responsible Machine Learning (TSRML), NeurIPS Workshop*, 2022.

[2] J. Harguess and C. M. Ward. Offensive security for AI systems: concepts, practices, and applications. In *Assurance and Security for AI-enabled Systems 2025*, volume 13476. SPIE, 2025.

[3] MIT FutureTech. The AI risk repository. arXiv:2408.12622v2, 2025.

[4] National Institute of Standards and Technology. Artificial intelligence risk management framework (AI RMF 1.0). Technical Report NIST AI 100-1, 2023.

[5] The MITRE Corporation. MITRE ATLAS. https://atlas.mitre.org/, 2024.

[6] C. M. Ward, J. Harguess, J. Tao, D. Christman, M. Tan, and P. Spicer. The AI security pyramid of pain. In *Assurance and Security for AI-enabled Systems*, volume 13054, pages 44–53. SPIE, 2024.